SIEM-SOAR

SIEM과 SOAR·사고 대응 자동화

연관 기출 · 127-3-6, 135-1-5

한눈에 이해

여러 로그를 모아 사건을 탐지하고, 탐지한 사건은 담당자와 대응 도구에 연결합니다.

정의와 핵심 원리

SIEM은 보안 이벤트를 수집·정규화·상관 분석하고 검색해 탐지와 조사를 지원합니다. SOAR는 여러 보안 도구·절차·사람을 플레이북으로 연결하고 반복 대응을 자동화·기록하는 기능군입니다.

• SIEM은 로그 시각을 맞추고 자산·사용자 정보를 함께 봅니다. 로그 품질을 점검하고 탐지 규칙을 조정합니다. 수집량 증가만으로 탐지 효과가 커지지 않으며 누락·오탐·저장 비용·프라이버시를 관리합니다. 전술·기법에 연결된 탐지로 유효성을 시험합니다.

• SOAR는 경보 수신 → 중복 제거·판단에 필요한 정보 조회 → 분류·우선순위 결정 → 승인 또는 자동 조치 → 티켓·증거 기록 → 종결·피드백을 구성합니다. IP 차단·계정 비활성화 같은 행위는 업무 영향·확신도·승인 기준·롤백·시간 제한이 필요합니다.

• SOAR는 도구 간 연계, 자동화 엔진, 사건 관리, 위협 정보 등으로 구성할 수 있습니다. 반복 업무 시간을 줄이고, 조치를 일관되게 수행하며 증거를 추적하는 데 도움이 됩니다. 평균 탐지·대응 시간(MTTD/MTTR), 오탐, 다시 조사한 사건, 자동 조치 실패를 확인해 효과를 평가합니다. 자동화 대상과 사람의 판단 경계를 명확히 합니다.

• 도구 연계용 계정과 API 토큰에 최소 권한을 부여합니다. 자격 증명을 교체하고 실행 기록을 감사해 자동화 플랫폼에 권한이 집중되는 위험을 줄입니다.

구조·비교·판단

구분	핵심 원리	적용·한계
SIEM	로그 수집·상관·탐지	이벤트 품질·탐지 규칙 조정
SOAR	도구·플레이북·대응	승인·권한·롤백
공통	사건 문맥과 감사	연계 API·운영 책임

적용 예제

피싱 메일 플레이북

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 직원이 신고한 메일에 의심스러운 URL이 있습니다.

1. 원본과 헤더를 보존하고 안전한 환경에서 URL 평판과 관측 기록을 확인합니다.
2. 동일 메일 수신 범위를 검색합니다.
3. 확신도와 업무 영향에 따라 승인 후 메일을 격리하고 도메인을 차단합니다.
4. 조치 결과·예외·복원을 기록하고 탐지 규칙을 보완합니다.

결과·해석: 자동화 속도와 잘못된 광역 차단 위험을 함께 관리합니다.

전제·주의: 플레이북은 조직의 권한·절차·업무 영향에 맞춰 시험해야 하며 자동 차단의 효과를 보장하지 않습니다.

답안 골격과 혼동 방지

등장 배경 → 수집 → 대응 구조 → SIEM과 SOAR 비교 → 플레이북 예제 → 도입·효과 측정

- SOAR가 SIEM이나 분석가를 완전히 대체한다고 쓰지 않습니다.
- 모든 경보를 무승인 차단으로 연결하지 않습니다.

내용을 가리고 회상

1. 오케스트레이션과 자동화는 무엇이 다릅니까?
2. 위험한 조치의 승인 기준은 무엇입니까?
3. 효과 측정에 오탐도 포함해야 하는 이유는 무엇입니까?

적용 기준과 근거

Microsoft 공식 SOAR 설명(2026-05-26)과 NIST/MITRE 근거로 원리·비교·운영을 확인했습니다. 제조사의 효과 주장을 보편 성과 수치로 옮기지 않았습니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- What is SOAR? - Microsoft Security; 2026-05-26 갱신; 확인 2026-11-05.
- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.
- NIST SP800-86 Integrating Forensics into Incident Response - Karen Kent et al. / NIST; 2006-08; 확인 2026-11-05.